

Access Control Policy

Identity, authorization and privileged-access requirements for MedCore information systems

Document ID	MC-IT-002
Version	2.2
Effective Date	01 September 2026
Review Cycle	Annual
Classification	Internal — Restricted

1. Purpose

This policy establishes controls for requesting, approving, provisioning, reviewing and removing access to MedCore applications, infrastructure and information.

2. Access Control Principles

Least privilege: users receive only the access required for their current responsibilities.

Need-to-know: access to sensitive information must have a legitimate business or care purpose.

Separation of duties: incompatible responsibilities should not be combined where practical.

Accountability: access must be attributable to an individual or formally approved technical identity.

3. Joiner–Mover–Leaver Lifecycle

Event	Trigger	Control
Joiner	New employee / contractor	Manager request, identity verification, role assignment and approval
Mover	Role / department change	Review existing access; add only required permissions; remove obsolete access
Leaver	Employment / contract ends	Disable access promptly; recover assets; revoke remote and privileged access

4. Access Request and Approval

Requests must identify the user, system, role, business purpose and duration where access is temporary.

Approvers must understand the user's responsibilities and should not approve access that is clearly outside the role.

High-risk, privileged or sensitive-data access may require additional Security or system-owner approval.

5. Privileged Access

Administrative accounts must be separate from routine user accounts where supported. Privileged credentials should not be used for everyday email, browsing or office work.

Privileged access should be time-limited where feasible and monitored through appropriate logging.

Emergency administrative access must be documented and reviewed after use.

6. Authentication Controls

Multi-factor authentication should be enabled for privileged access, remote access and systems containing sensitive information where technically supported.

Inactive accounts should be disabled according to risk and operational requirements. Default vendor credentials must be changed before production use.

7. Periodic Access Reviews

Access type	Typical review	Review focus
Standard application access	Quarterly / risk-based	Role fit, inactive users, obsolete permissions
Sensitive-data access	Quarterly	Business need, unusual access, manager confirmation
Privileged access	Monthly / quarterly	Named administrators, scope, emergency use, logs
Vendor access	Per contract / quarterly for high-risk	Current need, expiry, sponsor and security controls

8. Remote and Third-Party Access

Remote access must use approved mechanisms and authentication controls. Vendor access should be linked to a named sponsor, limited to the required systems and removed when the engagement ends.

Unmanaged devices may not be used for restricted information unless explicitly authorized and protected by required controls.

9. Exceptions and Break-Glass Access

Exceptions require documented justification, risk assessment, compensating controls, approver and expiry date. Emergency access must be attributable and reviewed after use.

10. Audit and Enforcement

Access records, approvals and review evidence must be retained in approved systems. Suspected inappropriate access is handled through the security incident process.

Failure to follow access-control requirements may result in access restriction, corrective action or other measures under applicable MedCore procedures.

Frequently Asked Questions

How quickly should a leaver's access be removed?

Access should be disabled promptly in line with the approved offboarding workflow and the person's risk, role and termination circumstances.

Can a manager approve all access for their team?

Managers can approve access only within their delegated authority and where they understand the business need. Sensitive or privileged access may require additional approval.

What happens when an employee changes departments?

Existing access should be reviewed. Required new permissions may be added after approval, while obsolete permissions should be removed.